CIS 4910

Information Technology

Sidebar — Laws & Regulations

FALL 2026

Professor Scot Hollingsworth
scoth@usf.edu • Office Hours by appointment (Microsoft Teams)

Disclaimer: I am not an attorney or regulatory expert. This material is educational, not legal advice.

SIDEBAR

Objectives

Laws

Understand laws vs. regulations.

Identify key federal IT and data laws.

Know which laws apply to your project.

Understand non-compliance penalties.

Regulations

Know how agencies write regulations.

Understand the CFR & Alphabet Agencies.

Identify regulations your project must meet.

Explore: should coding require a license?

FOUNDATIONS

Laws vs. Regulations: The Key Difference

Laws

Created by Congress, states, or cities.

Arranged by subject in the U.S./ State Codes.

Can impose civil or **criminal** liability and penalties.

Example: HIPAA, CFAA, FERPA. Usually contains the word “Act”.

Regulations

Created by agencies: the Alphabet Agencies (ATF, FCC, SEC, FTC, HHS, EPA).

Usually impose only civil penalties; There are exceptions (ATF)!

Arranged by subject in the CFR (Code of Federal “**Regulations**”)

Post-Chevron: courts interpret statutes & associated regulation now.

Who Creates the Regulations That Affect IT?

FTC

Federal Trade Commission

Enforces consumer data protection and penalizes companies that fail to secure user data.

HHS

HHS / Office for Civil Rights

Enforces HIPAA for any system that stores or transmits protected health information.

FCC

Federal Comms. Commission

Regulates radio, TV, cable, and internet under the Communications Act of 1934.

Who Creates the Regulations That Affect IT?

SEC

Securities & Exchange Comm.

Requires public companies to disclose cybersecurity incidents within four business days.

DOT

Dept. of Transportation

Regulates drones, autonomous vehicles, and FAA-connected hardware capstones.

DOJ

Dept. of Justice / FBI

Prosecutes CFAA violations: hacking, unauthorized access, and malware deployment.

YOUR CAPSTONE PROJECT · PART 1 OF 2

Which Laws Apply to Your Project?

Every software system that touches people or data is subject to at least one law.

1	**Who is your user?**	Healthcare users need HIPAA; students need FERPA; children need COPPA.
2	**What data do you store?**	Health, student, financial, and biometric data each carry distinct obligations.
3	**Which states are involved?**	25+ states have privacy laws; CA, TX, FL, and VA add specific requirements.

YOUR CAPSTONE PROJECT · PART 2 OF 2

Which Laws Apply to Your Project?

4	**Is your sponsor public?**	SEC rules require breach disclosure within four business days for public companies.
5	**Radio or wireless?**	Any Wi-Fi, Bluetooth, or RF component, even a prototype, falls under FCC rules.

Federal IT Laws

The statutes that directly affect data, security, and software.

FEDERAL LAW

HIPAA and FERPA: Health and Student Data

HIPAA (1996)

Health Insurance Portability & Accountability Act.

Protects patient health information (PHI).

Penalties: up to $50,000 per violation.

Applies to: apps storing patient health data.

FERPA (1974)

Family Educational Rights & Privacy Act.

Protects student records at funded schools.

Third parties need written consent.

Applies to: systems with grades or transcripts.

FEDERAL LAW

CFAA and ADA — Security and Accessibility

CFAA (1986)

Computer Fraud and Abuse Act — anti-hacking law.

Criminalizes unauthorized computer access.

Penalties: fines to 10–20 years imprisonment.

Applies to: security testing your project runs.

ADA / Section 508 (1990)

Requires accessible technology by law.

WCAG 2.1 AA is the accepted standard.

Penalties: funding loss and civil lawsuits.

Applies to: any public-facing web or mobile app.

FEDERAL LAW

GLBA & COPPA: Financial and Children's Data

GLBA (1999)

Gramm-Leach-Bliley Act protects financial data.

FTC Safeguards Rule (2023) requires a security plan.

Covers banks, insurers, and fintech apps.

Applies to: any fintech capstone project.

COPPA (1998, updated 2025)

Protects data of children under 13.

2025 update tightens parental consent rules.

Compliance required by April 22, 2026.

Applies to: apps or games used by kids.

Incident Reporting: SEC and CIRCIA

SEC Cybersecurity Rule

Public firms must disclose incidents within 4 days.

Requires an annual cybersecurity governance report.

Applies to all SEC-registered companies.

A breach at a public sponsor becomes public.

CIRCIA (2022)

Cyber Incident Reporting for Infrastructure Act.

Reports to CISA due within 72 hours.

Ransomware payments reported within 24 hours.

Covers all 16 critical infrastructure sectors.

State Privacy Laws

25+ states have enacted comprehensive privacy laws, and counting.

The State Privacy Law Wave

CA

California - CCPA / CPRA

The first and strictest law, granting rights to access, delete, and opt out of data sales.

TX

Texas - TDPSA (2024)

Covers businesses processing data of 100,000+ Texas residents; AG enforcement only.

FL

Florida - FDBR (2023)

Covers large tech controllers over $1B in revenue, with opt-out rights for targeted ads.

The State Privacy Law Wave

VA

Virginia - CDPA (2021)

One of the first state laws, covering 100,000+ residents with a GDPR-inspired structure.

WA

Washington - MHMD (2023)

The broadest consumer health data law in the US, extending well beyond HIPAA.

IL

Illinois - BIPA (2008)

Requires consent before collecting fingerprints or face scans; allows private lawsuits.

What These Laws Require

R **Consumer Rights**	Access, correct, delete, and opt out — all state laws grant residents these rights.
P **Privacy Notices**	Organizations must clearly disclose what data they collect and why, before collecting it.
D **Data Minimization**	Collect only what is necessary; the CPPA made this an enforcement priority in 2024.

What These Laws Require

S **Security Safeguards**

Reasonable security is required, scaled to the sensitivity of the data involved.

B **Breach Notification**

All 50 states require consumer notice within 30 to 72 hours of a breach.

Florida IT and Data Governance Laws

F	**FL Digital Bill of Rights (2023)**	Grants Floridians opt-out rights for targeted ads, data sales, and profiling.
I	**FL Information Protection Act**	Requires reasonable security; breaches of 500+ records go to the FL AG within 30 days.
C	**FL Computer Crimes Act**	Florida's version of the CFAA (Ch. 815); criminalizes unauthorized access and fraud.
E	**FL Electronic Surveillance Act**	Requires all-party consent to record communications, stricter than federal law.

AI & Emerging Tech Law

The regulatory frontier: moving faster than Congress.

Regulating Artificial Intelligence

1	**EU AI Act (2024)**	World's first comprehensive AI law, risk-tiered by category.
2	**Colorado SB 205 (2026)**	First US state law requiring reasonable care against AI bias.
3	**DOJ Bulk Data Rule (2024)**	Bars bulk transfer of US personal data to countries of concern.
4	**Illinois BIPA**	Requires consent before collecting fingerprints or face scans.

Frameworks Are Not Laws — Until They Are

1	**NIST CSF 2.0 (2024)**	Voluntary, but treated as mandatory by federal contractors.
2	**SOC 2 Type II**	An audit standard enterprise customers often require by contract.
3	**PCI DSS 4.0**	Required by Visa, Mastercard, and Amex for handling card data.
4	**CMMC (Defense)**	Required for all DoD contractors since 2025, in three tiers.

THOUGHT EXPERIMENT

Should Software Development Be Licensed?

Doctors, lawyers, and engineers must pass exams and carry personal liability.

Arguments For

- Software defects can cause real injury.
- Developers currently face little personal liability.
- Security by design would become a legal duty.

Arguments Against

- Licensing could raise barriers for startups.
- Software evolves faster than static licenses.
- Liability already exists via contract law.

CAPSTONE TAKEAWAY · PART 1 OF 2

What Your Project Must Address

1	**Identify applicable laws**	Your SRS must name every federal and state law that applies to your data and users.
2	**Know your data types**	Health, financial, biometric, and student data each carry distinct legal obligations.
3	**Geography matters**	Users in CA, TX, FL, or VA trigger state-specific requirements on top of federal law.

CAPSTONE TAKEAWAY · PART 2 OF 2

What Your Project Must Address

4	**Security is not optional**	Every law covered today includes a security component scaled to data sensitivity.
5	**Breach plans are required**	All 50 states require breach notification, and public sponsors face SEC deadlines.
6	**AI adds a new layer**	Systems using AI for decisions about people face fast-emerging legal obligations.

End

Laws & Regulations